

AccsMarkets — Deep Audit

What was added and fixed, what is still missing, and what to build next

accsmarkets.org · Next.js 14 · Prisma / MySQL · audit date 22 September 2026

This report covers the whole codebase: the admin panel (36 pages, ~90 admin API routes), the user-facing site (43 public routes, 30 dashboard routes), and the backend (233 API route files, libraries, middleware, schema with 78 models, sweep/cron, socket server). Every finding below was located in the source with file references; the items marked **FIXED** were changed during this engagement.

3

critical auth holes found
(session forgery, admin 2FA bypass, token confusion)

300+

files fixed across three
production releases

12 / 17

dashboard sections that
were unreachable on a
phone (now fixed)

25

database models with no
admin page managing them

FIXED done this engagement **PARTIAL** exists but incomplete **MISSING** not built **EXTERNAL** needs action outside the code **OK** verified working

1. What was added and fixed

1.1 Release v2.0.2 — deployed

Area	Change
Sold listings	SOLD listings now appear in the main marketplace with a SOLD overlay; sellers can Relist a sold listing (<code>POST /api/listings/[id]/relist</code> , audit-logged).
KYC	Public KYC Policy page, mandatory consent pop-up before starting KYC, footer link. KYC document URLs encrypted at rest (AES-256-GCM).
Email delivery	Transactional email now goes through the Brevo HTTP API first (Gmail SMTP times out from the VPS), SMTP kept as fallback.
Missing emails wired	KYC submitted · listing submitted for review · subscription activated · dispute opened (both parties) · withdrawal requested · admin high-risk alert · subscription renewal reminder (3 days before expiry).
Email content	Empty placeholders filled with real values in deposit-confirmed, escrow-completed, KYC-rejected, subscription-activated and offer-accepted emails. Hardcoded phone number removed from every email footer (now <code>SUPPORT_PHONE</code> env or support email).
Promotions	Critical bug: featured / pinned boosts never expired — the flags were never cleared. Sweep now clears expired boosts and notifies the seller.
Rate limits	KYC upload (5/h), KYC submit (3/day), AI intelligence (20/h).
Security	AutoSEO webhook no longer falls back to a secret hardcoded in the repo; rejects when the env var is unset.

1.2 Operations — live on the VPS

Item	Status	Detail
------	--------	--------

Transactional email delivery (OTP, forgot password, all notifications)	EXTERNAL	Root cause of the "OTP / reset emails don't arrive" problem: Brevo rejects every request from the server — "unrecognised IP address". The fallback (Gmail SMTP) times out from the VPS, so nothing is delivered. Fix in Brevo → Security → Authorised IPs: add <code>202.61.195.76</code> and <code>2a03:4000:58:e91:b8b8:6ff:feaf:1668</code> , or disable the IP restriction. No code change can work around this.
Hourly database backup	FIXED	Backup script was Windows-only (hardcoded XAMPP path) and mis-parsed <code>DATABASE_URL</code> . Now cross-platform; cron at :48 every hour; keeps last 7. Verified: 4.56 MB dump → 786 KB gz. A fresh dump was also downloaded locally.
Google Drive off-site copy	EXTERNAL	Fails with "OAuth client was disabled". The client must be re-enabled in Google Cloud Console (or a new refresh token issued). Until then backups exist only on the same VPS as the database.
Sweep job scheduling	FIXED	Nothing on the VPS was calling the sweep — offers, boosts, subscriptions and reminders were never processed in production. Added <code>scripts/run-sweep.sh</code> (reads the secret from <code>.env</code>) and a 15-minute cron. Verified <code>ok:true</code> on all 10 steps.
Sweep promotion step	FIXED	Step selected a non-existent <code>Listing.userId</code> and failed on every run; corrected to <code>sellerId</code> .
Line endings	FIXED	<code>.gitattributes</code> pins <code>.sh / .mjs</code> to LF so scripts copied from Windows run on Linux.

1.3 Release 9fa63ea — deployed (39 files)

Area	Change
Admin · KYC review	Admins could not see any KYC document. URLs were encrypted on write and rendered raw as <code></code> — every thumbnail was a broken image, so approvals were blind. Now decrypted server-side, with fallback for older plaintext rows.
Admin · Disputes	No dispute could be resolved from the admin panel. The resolve UI (buyer wins / seller wins / close) was built but never mounted; the only reachable control changed the "phase" without releasing escrow funds. Now mounted for open disputes.
Paid promotions	Sellers paid for placement they did not get. The browse page ignored every boost flag and the \$2 bump. Default sort is now premium → featured → pinned → bumped → newest; sold listings sink below active; bumps last 7 days.
Dashboard on mobile	No mobile navigation existed — only 5 bottom tabs, so My Listings, Offers, Escrows, Notifications, Saved Searches, Wanted, Referrals, Organization, Developer and more were unreachable on a phone. Added a slide-in drawer with the full menu. Theme toggle added to the dashboard header.
Admin on mobile	Contact inbox (master/detail), email-template editor, settings tabs, staff modals (Save button was off-screen), blog editor, all 6 data tables (now scroll instead of crushing), stat grids, filter rows, long IBAN/title overflow. Audit Log added to the sidebar; real Prev/Next on bank transfers.
User-side mobile	AI widget width, profile stats grid, listing trust grid, API docs table, offer action rows, notification-preferences grid.
Withdraw minimum	The page read the minimum from an admin-only endpoint (always 403), so the admin-configured value never applied. Added a user-facing endpoint.
Accuracy of public copy	Privacy and Cookie pages claimed "no third-party advertising or tracking" while the site loads Google AdSense, GA4 and the Meta Pixel. Corrected. FAQ updated for bank-transfer deposits. No-op "Most relevant" sort removed.

1.4 Release 3 — security, emails, SEO, icons (≈230 files)

Area	Change
Login security	Apple sign-in now verifies the token signature against Apple's keys; admin 2FA exemption removed from mobile login; Google token audience checked; social sign-in can no longer bypass 2FA; failed 2FA codes count toward lockout; OTP / 2FA endpoints limited to 5 tries per 15 min; abandoned 2FA setup no longer locks the account; admin 2FA uses the same cipher as login (it previously bricked the account).
Money & access	Withdrawals require phone-level KYC; AI listing analysis checks ownership; presence endpoint requires login; WhatsApp webhook fails closed; security headers added (HSTS, nosniff, frame, referrer, permissions); staff permissions <code>MANAGE_KYC</code> / <code>MANAGE_REPORTS</code> actually enforced on the API.
OTP / forgot password	Root cause found (section 1.2). In code: OTP no longer says "sent" when delivery failed; resend cooldown fixed; Google-only accounts can set a password by reset; reset clears the login lockout, emails a "password changed" notice and is rate-limited; reset page has confirm field + live rules; forgot-password has resend + spam hint; failed verification offers a new link.
Automatic emails	New sign-in from a new IP (real IPs now recorded); escrow-created email to the buyer; withdrawal approved; offer expired (both sides); advance warnings 24 h before an escrow deadline, dispute-evidence deadline and boost expiry, 12 h before an offer expires; low-balance notice after a boost purchase.
Promo emails	Marketing sweep bugs fixed: a failed send was recorded as sent (campaign lost forever), unverified addresses were emailed, the abandoned-offer button led to a 404, and no promo email had an unsubscribe link . Cron scripts added for the marketing sweep and the daily promo email — neither was ever scheduled on the server.
Email templates	All 26 HTML templates had invalid table markup (rows outside a table) — fixed. Escrow email said "Awaiting funding" for an already-funded escrow. Reset email now shows the real requesting IP instead of "Unknown".
SEO	41 pages had doubled titles ("... — AccsMarkets — AccsMarkets"). Every page without its own canonical was inheriting the homepage as canonical — fixed, with unique descriptions and canonicals on every public page. Duplicate profile URL canonicalised; noindex on auth, dashboard, admin, maintenance; sitemap now includes resources and KYC policy and refreshes hourly; FAQ and seller-profile structured data; sold listings get proper titles. The social share image was a 1×1 pixel placeholder — replaced with a real 1200×630 image.
Icons & UX	One modern icon set (Lucide) across ~92 files; emoji-as-icon reduced from ~200 lines to a handful of intentional ones; all navigation surfaces converted; icon-only buttons got labels and focus rings. Community pop-up no longer stacks on the cookie banner; announcement bar collapses to two lines on phones; 2FA status shows correctly.
Hidden type errors	All 14 cleared (maintenance-page crash, tab bar, AI provider chain, missing dependency, admin listings query, follow-button count, two admin routes). The project now typechecks with zero errors.

2. Security findings

Sev.	Finding	Status
CRITICAL	Apple mobile sign-in never verified the token signature. <code>api/auth/apple-mobile</code> only base64-decoded the JWT, so anyone could forge a token for any email — including an admin — and receive a real 7-day session.	FIXED
CRITICAL	Mobile login exempted admins from 2FA. <code>api/auth/mobile</code> skipped the 2FA lookup for <code>role === ADMIN</code> ; a leaked admin password bypassed 2FA entirely.	FIXED
HIGH	Google mobile sign-in did not check the token audience. A Google token issued for any other app was accepted.	FIXED
HIGH	No KYC gate on withdrawals. Selling requires phone verification, but a user at email-only level could request a payout. No step-up (2FA / email confirm) for large withdrawals; bank details stored as unencrypted JSON in <code>Transaction.meta.data</code> .	KYC gate FIXED · rest OPEN
HIGH	Enrolling admin 2FA bricks the admin account. Admin routes encrypt the TOTP secret with one cipher/key; login decrypts with another. Admin TOTP was therefore never actually verified at login.	FIXED
HIGH	Opening the 2FA setup page and leaving locks the account out — the row is created before the code is confirmed and login treats row existence as "2FA on".	FIXED
HIGH	Unlimited guessing of 6-digit codes — failed TOTP is not counted toward logout; email OTP confirm and <code>2fa/verify</code> have no attempt limit.	FIXED
HIGH	Bans, demotions and "revoke session" do not take effect for up to 7 days. Sessions are stateless JWTs with no DB check; deleting an <code>ActiveSession</code> row is cosmetic. Password reset does not evict an attacker.	OPEN
HIGH	KYC documents are publicly readable by URL (unsigned Cloudinary delivery / "anyone with link" on Drive). Encryption protects the pointer in the DB, not the passport image. Submitted URLs are also not bound to the uploader.	OPEN
MEDIUM	No security headers at all (HSTS, X-Frame-Options, nosniff, Referrer-Policy, Permissions-Policy). CSP still needs its own pass because of AdSense / GA4 / Meta Pixel.	FIXED · CSP open
MEDIUM	Staff permissions are editable but enforced on only 4 of 36 admin pages; the sidebar shows every link to every staff member. <code>MANAGE_KYC</code> , <code>MANAGE_REPORTS</code> , <code>VIEW_AUDIT_LOG</code> were never used, so KYC review required full user-admin rights.	API FIXED · pages OPEN
MEDIUM	Password reset sends no "password changed" email and has no rate limit.	FIXED
MEDIUM	AI listing analysis had no ownership check — any user could get the valuation of a competitor's draft or private listing.	FIXED
MEDIUM	WhatsApp webhook processed unsigned requests when its secret was unset; signature compare could throw. User presence endpoint required no login.	FIXED
MEDIUM	Wallet ledger drift: balances are <code>Decimal</code> in MySQL, but <code>balanceBefore/After</code> are computed with JavaScript floats in ~20 routes; partial crypto payments are credited unrounded.	OPEN

MEDIUM	~25 sensitive routes have no rate limit (uploads 10 MB × unlimited, promote, promo redeem, reviews, reports, deposit create, password change, public search). Lockout is email-only (IP always recorded as "unknown") → anyone can lock any account out.	OPEN
LOW	Uploads trust the client-declared MIME type (no magic-byte check); KYC accepts images only, no PDF. hCaptcha failed open when unconfigured.	PARTIAL
LOW	<code>next.config.js</code> has <code>ignoreBuildErrors</code> and <code>ignoreDuringBuilds</code> on — type errors ship silently (this is how the broken sweep step reached production).	OPEN

OK Verified solid: all 82 admin API routes check the ADMIN role · NOWPayments and Stripe webhooks verify signatures and are idempotent · no SQL injection (all raw SQL parameterised) · no secrets hardcoded in `src/` · Socket.IO authenticates on connect and scopes rooms per user · bcrypt cost 12 · balance updates use guarded atomic writes.

Do this today, outside the code: the VPS root password was shared in plain text during this work. Change it, switch SSH to key-only login, and disable root password auth.

3. Admin panel

3.1 Functional defects

Defect	Status
KYC document viewer showed ciphertext instead of images	FIXED
Dispute resolution controls never mounted — funds stuck in disputed escrows	FIXED
Audit Log page existed but was not linked anywhere	FIXED
Bank transfers: "Use ?page=2 to paginate" text instead of buttons	FIXED
KYC panel shows AI score / face-match / liveness / OCR widgets that are always empty — nothing ever writes those fields	MISSING
Dispute evidence file attachments: schema field exists, no upload and no viewer	MISSING
Staff permissions not enforced on 32 of 36 pages; sidebar not permission-aware	OPEN
No pagination on withdrawals, deposits, verification, subscriptions, announcements, contact messages, risk, apps	OPEN
No bulk actions anywhere (listings, users, reports, KYC, withdrawals)	MISSING
"Change plan", "Set badge", "Award achievement" ask the admin to type raw IDs / enum strings instead of a dropdown	OPEN
Verification queue shows only pending items — approved / rejected history cannot be viewed	OPEN
Security flags are counted but cannot be listed or resolved; flagged chat messages (<code>moderationFlagged</code>) are never shown to anyone	MISSING
Announcements cannot be edited or scheduled (start/end fields exist, no UI)	OPEN
Analytics: fixed 7/30-day windows, no date range, no export, no funnel, MRR, dispute rate, GMV vs net	PARTIAL
Staff invites can be sent but there is no endpoint to accept one	MISSING
~1,100 lines of dead admin components and 13 unused admin list/detail API routes	CLEANUP

3.2 Admin pages that do not exist

Missing page	Why it matters
Promotions / Boosts	Admins cannot see, grant, extend or cancel a single boost. No revenue view for promotions.
Ads / Advertisers	No ad model, no banner slots, no advertiser accounts, no impressions or billing. "Sponsored" is only seller self-promotion; third-party ads are raw AdSense.
Promo / Coupon codes	PromoCode + redemption models and a working redeem API exist, but codes can only be created by hand in MySQL, and there is no field anywhere for a user to enter one.
Risk case detail (<code>/admin/risk/[id]</code>)	No drill-down to the user, device, IP or login history behind a risk score.
Reviews moderation	An abusive or retaliatory review cannot be removed.

Wanted listings moderation	User-posted "wanted" ads have no review queue at all.
Auctions / bids	No bid viewer, no way to void a fraudulent bid.
Organizations	No list, suspend or ownership transfer.
API keys & webhooks	User API keys cannot be listed or revoked; no failed-delivery queue or manual retry.
Sessions & login attempts	No brute-force viewer, no force-logout of a user, no reset of a user's locked 2FA.
User impersonation / support view	No "view as user" for support.
GDPR data-export requests	Erasure has a queue; export requests do not.
Notifications / push broadcast, NPS results, marketing send history, fiat payments reconciliation, deposit-method fees	Data is collected or configurable in the schema with no admin surface.

4. User-facing site

4.1 Seller

Feature	Status	Detail
Per-listing analytics	MISSING	No page. API returns only views / offers / days active and nothing calls it. View events with country and day are already stored. "Advanced analytics" is sold on the plans page.
Earnings breakdown	PARTIAL	Totals only. No by-listing / by-month view, no date range, no CSV.
Promotion management	MISSING	Can buy a boost, but cannot see expiry, history, cancel or extend. Re-buying silently overwrites the expiry.
Bulk tools / pause listing	MISSING	No bulk actions. No <code>PAUSED</code> status exists, and an <code>ACTIVE</code> listing cannot even be deleted. "Bulk tools" is sold on Pro / Enterprise.
Duplicate listing / templates	MISSING	
Storefront	PARTIAL	Shows 12 listings with no "view all". Two parallel profile pages (<code>/seller/...</code> and <code>/profile/...</code>) compete for SEO.
Saved payout methods	MISSING	Bank / crypto details retyped on every withdrawal; no PayPal; no "new destination" alert.
Invoices / tax export	MISSING	Only a bank-deposit receipt exists. No sale / purchase receipt, no annual summary.
Price suggestion when creating a listing	PARTIAL	The AI valuation exists but only in the floating widget — not in the listing form where the price is set.

4.2 Buyer and shared

Feature	Status	Detail
Watchlist, saved searches + alerts, offers + counter-offers, reviews, referrals, messaging (real-time, attachments, read receipts), notification centre + preferences, TOTP 2FA, sessions page, GDPR requests, PWA + push, sitemap / robots / OpenGraph / JSON-LD	OK	Implemented and working.
Dispute centre	MISSING	Disputes are visible only inside each escrow; the phase timeline is admin-only.
Support tickets	MISSING	Contact form → email only. No ticket list, status, thread or reference number.
Card deposits (Stripe)	BROKEN	Fully coded, but the <code>stripe</code> package is not installed, so the tab always shows "not configured".
Promo code entry	MISSING	Redeem API exists; no input field anywhere.
Purchased credentials	PARTIAL	Shown read-only; no copy / download, no purchase receipt.

Search	PARTIAL	No niche / category filter although every seller fills in a niche. A complete full-text relevance search API exists but nothing uses it. "Verified" filters by seller KYC, not by verified account ownership.
Compare listings · loyalty points · price-drop target alerts	MISSING	
Languages (i18n)	NOT WIRED	English + Spanish files exist (a few dozen strings) but the locale is hardcoded to English, no component reads translations, and there is no language switcher.
2FA backup codes · user passkeys	MISSING	Admins have passkeys; users do not. No recovery codes shown.
Data export	PARTIAL	Emailed on request; omits offers, watchlist, saved searches, notifications, KYC, disputes.
Cookie consent	PARTIAL	AdSense, GA4 and Meta Pixel load regardless of the visitor's choice — a GDPR exposure.

5. Intelligence, KYC auto-verify and fraud

Capability	Status	Detail
Listing analysis, buyer recommendations, price valuation, market trends, AI blog	OK	Working, 4-provider fallback (Groq → Grok → OpenAI → Gemini), each with a non-AI fallback.
KYC auto-verify from uploaded pictures	MISSING	There is no image analysis of any kind : no OCR, document classification, face match, liveness, tamper or duplicate-document check. The schema and admin UI are already built for the results (ocrName, ocrDob, ocrDocNumber, ocrExpiry, kycScore, isLive, faceSimilarity) — nothing writes them. The AI layer is text-only today; Gemini and OpenAI support vision and can do OCR + document-type + quality scoring. Face match and liveness need a real biometric model — a chat model will invent a plausible number, which is worse than leaving it empty.
Risk engine	PARTIAL	4 rules; the heaviest (shared device = multi-account) can never fire because device fingerprints are never recorded. Scores are computed only at signup and escrow creation, and gate nothing — a CRITICAL user can still withdraw.
Listing fraud screening	MISSING	Regex only. No duplicate-listing check (the same account URL can be listed unlimited times), no price-anomaly check, no fake-follower plausibility check, no stolen-screenshot detection.
Chat scam detection	PARTIAL	Regex blocks links / contact handles; flagged messages are stored but no one can review them.
"Risk summary" AI feature	WEAK	Re-phrases existing flags and shows them to the flagged user — it tips off the subject without restricting them.

6. Warnings and automatic emails

Warning / email	Status
KYC submitted · listing submitted · subscription activated · dispute opened · withdrawal requested · renewal reminder · boost expired · admin high-risk alert	FIXED
Price drop on watchlisted listing · new match for saved search · listing rejected with reason · deposit confirmed · subscription expired	OK
Withdrawal approved / completed email	FIXED
Offer expired (both parties were never told)	FIXED
New sign-in from a new IP — alert email + security notification (login IPs now recorded)	FIXED
Escrow deadline and dispute-evidence deadline — warning 24 h <i>before</i> (previously only after)	FIXED
Boost expiring tomorrow · offer expiring in 12 h · escrow-created email to buyer	FIXED
Low wallet balance (after boost purchase only)	PARTIAL
Large-withdrawal confirmation · payout destination changed	MISSING
KYC document expiring / re-verification	MISSING
Email preference toggles: honoured by all new emails; ~35 older send sites still ignore them	PARTIAL

Marketing sweep + daily promo email: scripts added and scheduled on the server; unsubscribe link added to every promo email

FIXED

One-click unsubscribe (no login) + List-Unsubscribe header; user security event log (`logUserEvent`) never called

OPEN

7. Recommended roadmap

P0 — this week (safety and money)

- **Authorise the server IPs in Brevo** — until then no OTP, reset or notification email is delivered.
- Rotate the VPS root password; SSH keys only.
- Make session revocation and bans immediate (token version / DB check on each request); invalidate sessions on password reset.
- Make KYC files private (signed, expiring URLs) and bind submitted URLs to the uploader.
- Re-enable Google Drive OAuth so backups leave the server.
- Enforce staff permissions on all admin pages; permission-aware sidebar.
- Let risk scores act: hold withdrawals for HIGH / CRITICAL; record device fingerprints and login IPs.
- Turn off `ignoreBuildErrors` now that the type errors are cleared.

P1 — next 2–3 weeks (things customers are already paying for)

- Seller promotion manager (active boosts, expiry, history, extend) + admin Promotions page.
- Per-listing analytics page; earnings breakdown with CSV export.
- Bulk listing tools and a PAUSED status.
- KYC auto-verify phase 1: vision OCR + document type + quality score → fill the existing admin widgets; auto-approve only above a threshold, otherwise manual review.
- Admin promo-code manager + promo-code field at checkout / deposit.
- Missing warnings: new-device login, escrow / dispute deadline approaching, large-withdrawal confirmation, low balance.
- Install Stripe (or remove the card tab); cookie consent that actually gates trackers.

P2 — following month (growth)

- **Advertising system:** advertiser accounts, banner / sponsored slots, scheduling, impressions and clicks, billing from wallet, admin approval queue.
- Support ticket system; user dispute centre with timeline and evidence uploads.
- Niche filter + switch browse to the existing full-text search; compare listings.
- Duplicate-listing and price-anomaly screening on listing creation; moderation queue for flagged messages.
- Saved payout methods (encrypted) with change alerts; invoices and receipts.
- Admin pages: reviews, wanted listings, auctions, organizations, API keys / webhooks, sessions, data-export requests; pagination and bulk actions everywhere.

P3 — later

- Real multi-language support; user passkeys and 2FA backup codes; loyalty points; affiliate tiers.
- Biometric face-match and liveness for KYC; KYC expiry and re-verification.
- Decimal-safe ledger arithmetic; full Content-Security-Policy; remove dead code and unused routes.